

Bài 1: Tổng quan

sẵn sàng (availability) ↑

Lý thuyết

- **Dữ liệu:** lưu trữ, truyền
- * **4 yc dữ liệu:** bí mật (confidentiality); toàn vẹn (integrity); từ chối (Non-repudiation) và sẵn sàng (availability)
- * **7 KT tấn công (cơ chế / tool / phòng):**
 - Eavesdropping: bắt gói thụ động, khó phát hiện, dễ trên wifi: tcpdump, ethereal, Wireshark | mã hóa DL truyền
 - Cryptanalysis: giải mã Q căn khóa, dựa tần suất ký tự | decode Q lộ thông kê + Key dài
 - Password Pilfering: Guessing + Social + Dictionary + Sniffing | Cain & Abel | MK dài, dùng SSH
 - Identity Spoofing: Q căn MK (MITM, Message replay, Network spoofing) | TCP Wrapper
- Intrusion
 - DOS/DDoS
 - Malicious Software / A/Ws
 - 5 nhóm
 - black hat hacker
 - Script kiddies *
 - Cyber spies
 - Vicious employees
 - Cyber terrorist
 - 5 giai đoạn
 - Reconnaissance (thăm dò)
 - Scanning
 - Gaining Access
 - Maintaining Access
 - Covering tracks (xóa vết)
- 4 phần mô hình BM:
 - CryptoSystem: mật mã + giao thức BM
 - Fire wall: app check gói tin vào và ra
 - AMS: quét + folder/file, xác mã độc
 - IDS: giám sát, phân tích log
- **Defend in Depth (Nguyên → trong):** Policies → Physical → Perimeter → Internal network → Host → app → data
- **Penetration testing:** định kỳ tấn công thử → báo cáo → đề xuất

Thầy nhắc + đề mã + VD mẫu

* **Quan trọng:**

- KT tấn công
- phân biệt attacker
- depend depth



- Wifi, ng chạy Wireshark đọc web HTTP ⇒ Eavesdropping
- Gọi điện tư xưng IT xin MK ⇒ Social engineering
- Lấy file SAM, thử list từ phổ biến ⇒ Dictionary

Mẹo nhớ

- Pilfering GSDS = Guess - Social - Dict - Sniffing
- DOS: Smurf - Buffer - Ping of Death - Teardrop - SYN
- TCP hijack ⇒ Transport
- Từ khóa:
 - 1) Bắt gói ⇒ Eaves;
 - 2) Q căn khóa ⇒ Crypta;
 - 3) Đoán/lừa/SAM ⇒ Pilfering
 - 4) Q căn MK/phát lại ⇒ Spoofing;
 - 5) công mở/scan ⇒ Intrusion;
 - 6) can tẩu ngựa zombie ⇒ DOS
- 3 cách chứng minh danh tính: MK - Sinh trắc - Giao thức CT
- Mã độc:
 - Virus (copy, cần file)
 - Worm (tự lây mạng, Q căn file)
 - Trojan (ngụy trang, Q căn sinh)
 - Logic bomb, back door, spyware
- Black hat: giết, tư viết tool (mũ trắng = bảo vệ, mũ xám = trắng, vi phạm)
- Script Kiddies: dùng tool
- Cyber spy: ăn danh, tình báo chính trị / quân sự FABICO
- Terrorist: khủng bố, phá hoại tầng

Cổ điển: mã thay thế đơn, dịch chuyển và Play Fair

Bài 2A: Mã hóa (Thiên đại: DES và AES)

Lý thuyết

- Nguyên lý Kerckhoffs: giải thuật công khai, an toàn nằm ở khóa
- Phân loại:
 - Cổ điển (thay thế, hoán vị)
 - Hiện đại:
 - Đối xứng: dùng 1 khóa, nhanh, (DES, 3DES, AES)
 - Bất đối xứng: dùng cặp khóa PU/PR, chậm hơn hàng ngàn lần (RSA)
 - Mã khối: theo khối 64/128 bit: DES, AES, IDEA, RC2... theo dòng (mã từng bit, đạt đến RC4)
- Caesar (dịch chuyển): $c = (x + K) \bmod 26$, có 25 khóa. Caesar gốc $K = 3$
- Thay thế đơn: có $26! \approx 4 \cdot 10^{26}$ khóa nhưng gửi nguyên tần suất chữ cái $\Rightarrow$ phá = thất bại (E ~ 12,7%)
- Play Fair:
 - 5x5, viết khóa bỏ chữ trùng + bảng chữ còn lại, I J chung
 - Cặp 2 chữ trùng $\rightarrow$ chèn X giữa; số chữ lẻ $\rightarrow$ thêm X ở cuối
 - Cùng hàng $\rightarrow$ lấy chữ bên PHẢI; Cùng cột $\rightarrow$ DƯỚI; Khác hàng/cột $\rightarrow$ gửi hàng lấy cột chữ kia
- DES: khóa 56 bit, khối 64 bit, 16 vòng. 1998 phá 56h. 2002 AES thay DES
- AES: Rijdael (Daemen & Rijmen), B?, khối 128 bit (mã + lần 4x4 byte); Khóa 128/192/256 bit; AES-128 = chạy 10 vòng, 11 khóa vòng (bỏ Mix column)
- 4 hàm: SubBytes (thay từng byte) $\rightarrow$ Shift Rows (hàng, hàng 1 giữ, 2/3/4 dịch 1/2/3) $\rightarrow$ Mix Column $\rightarrow$ Add Round Key (XOR khóa vòng)
- RSA:
 - Mã = PU người nhận $\rightarrow$ Bảo mật
 - Mã = PR ng gửi $\rightarrow$ Chứng thực
 - Mã lai: AES mã dữ liệu, RSA: mã khóa phiên

Mẹo

- Play Fair: để hỏi ký tự n thì chỉ cần mã đến cặp thứ $[n/2]$
- DES: khóa 56 (không phải 64, nó là khối), 16 vòng
- AES: khối 128, không phải 256 (256 là khóa), 3 cỡ khóa, 10 vòng
- Đối xứng = 1 khóa nhanh; Bất đối xứng = 2 khóa chậm hơn ngàn lần
- Công khai = KHỎA, Bí mật = MẬT (PU mã hóa, PR giải)

Độ an toàn theo độ dài khóa

Khóa	Số khóa	Thời gian TB
32 bit	$4,3 \times 10^9$	$\sim 2,15$ mili giây
56 bit (DES)	$7,2 \times 10^{16}$	~ 10 giờ
128 bit (AES)	$3,4 \times 10^{38}$	$5,4 \times 10^{18}$ năm
168 bit (3DES)	$3,7 \times 10^{50}$	$5,9 \times 10^{30}$ năm
26 ký tự hoán vị	$26! \approx 4 \times 10^{26}$	$6,4 \times 10^6$ năm

Bài 13: Chứng thực dữ liệu

- CT là confirm nguồn gốc + thuật phục DL → toàn vẹn dữ liệu
- CT ≠ BM: BM là giấu nội; CT là confirm nội gửi và để nguyên vẹn
- 3 pp CT: mã hóa thông điệp + MAC + hàm băm
- 4 công dụng MHTĐ: $E(K, M)$ BM + CT; $E(Pub, M)$ BM

MAC: dùng chung khóa bí mật (A-B). Đầu cuối cố định $MAC = C(K, M)$
 (MAC 32-96 bit), (K 56-160 bit) B dùng cùng K tính lại MAC
 nếu khớp ⇒ 0 bị sửa, nếu khác ⇒ bị sửa ở 1 giả mạo

3 công dụng MAC: a) $M || C(K, M) ⇒ CT$; b) $E(K, [M || C(K, M)])$
 ⇒ CT + BM (CT gắn plaintext); c) $E(K, M) || C(K, E(K, M)) ⇒$
 CT + BM (CT gắn với ciphertext)

- S = từ bí mật chung A và B (như khóa phiên, dùng 1 lần)
- MD5 vs SHA: MD5 → 128 bit (32 ký tự hex)
- SHA-1 → 160 bit (TLS, SSL, PGP, SSH, S/MIME, IPsec)
- SHA-2 → SHA-224/256/384/512
- SHA-3 → dùng Keccak

Chữ ký số (CKS): tạo (A): băm M → mã H(M) bằng PRa (thường RSA) → gắn chữ ký vào M: $M || E(PRa, H(M))$
 Kiểm (B): giải chữ ký = PRa → mã băm 1; từ băm M nhận đc → mã băm 2; so sánh
 tương → toàn vẹn và đúng A gửi.

Cung cấp: CT + toàn vẹn + chống chối bỏ

Mô hình đầy đủ: $E(Pub, K) || E(K, [M || E(PRa, H(M))])$

- Quy tắc đọc biến thứ:
- 1) Trong ngoặc làm tác, ra dần ngoài, bên nhận thao tác ngoài tác
 - 2) Có H(...) ⇒ CT/toàn vẹn
 - 3) Có $E(PRa, ...)$ (khóa riêng người gửi) ⇒ CKS
 - 4) Cả khối bị mã bởi $E(K, ...)$ hoặc $E(Pub, ...)$ ngoài cùng ⇒ BM
 - 5) Có S trong băm ⇒ CT nhờ bí mật chung, không chữ ký
 - 6) Loại suy: hình 0 có PR thì loại đáp án có PRa. M đi dạng rõ thì loại đáp án có E(K) bọc ngoài.

Mẹo: $[!]. E(K, [M || E(PRa, H(M))]) ⇒ BM + CT + CKS$ | câu khác: hình băm M ghép S, M đi rõ ⇒ $M || H(M || S)$

[!]: đề mẫu [G]: Loại suy hình: 0 có PR ⇒ Loại đáp án PRa. M đi dạng rõ ⇒ Loại bọc E(K) ngoài

[G]: giải [B]: $M || E(K, H(M))$: Có E(K) nhưng chỉ bọc H(M), vẫn rõ ⇒ 0 BM

[B]: bẫy [B]: $E(K, M)$ đối xứng: Có CT nhưng 0 CKS

[M]: nhớ [B]: $E(Pub, M) = BM$, 0 CT (ai cũng có Pub)

[B]: MAC 0 thay K bằng PU/PR được. MAC có khóa, hàm băm thì 0

[B]: CKS của 2 văn bản ≠ thì luôn ≠. Ký = PR người gửi, Kiểm = PU người gửi (0 phải người nhận)

[B]: mã băm trùng chỉ chứng minh file nguyên vẹn, 0 chứng minh sạch mã độc

[N]: H = CT; PR = Chữ ký; E bọc ngoài = BM; S = bí mật chung

[N]: độ dài băm MD5-128; SHA1-160; SHA2-224 tới 512

[N]: CKS: Băm → khóa riêng Ký → khóa công khai Kiểm → so 2 mã băm

[N]: MAC dùng khi 2 bên quen biết (có khóa chung, vd: Ngân hàng). Băm dùng khi 0 quen biết (check file tải về)

Bài 3A+3B: Thăm dò + Quét Mạng

Lý thuyết

(3A) - 3 đối tượng thăm dò (để cho 1 thông tin → hỏi thừa nhóm nào):
1) **Mạng** = info về "địa chỉ": tên miền, dải IP, TCP/UDP, VPN, ACL, IDS, cơ chế chứng thực.
2) **Hệ thống** = info về "tầng máy": bảng định tuyến, SNMP, tên máy, banner, user/group, kiến trúc.
3) **Tổ chức** = info về "cơ sở": nhân viên, địa chỉ nhà, SĐT, danh bạ.

- **Mối đe dọa khi bị TĐ**: Social engineering / rò rỉ / mất riêng tư / giám điệp / thiết hại kinh doanh.
- **(KT + công cụ)**:
1) **WHOIS** → tra 4 nhóm (domain, chủ sở hữu, máy chủ, dải mạng). Do **5 RIR** qly: ARIN, AfriNIC, APNIC, LACNIC, RIPE NCC.
2) **DNS (nslookup)**: 13 máy chủ gốc, Bảng ghi: A=IP, MX=mail, NS=name server, CNAME=bi danh, PTR=IP → tên, SOA=tham quyền, HINFO=CPU hệ điều hành (nguy hiểm nhất).
3) **Trace route / tracer**: tìm path + vị trí firewall. Dùng ICMP + TTL: gửi TTL=1,2,3... mỗi router trừ 1, về 0 thì báo lỗi → là từng router. Dấu * = gói mất.

4) **Website**: xem HTTP header; Wayback Machine xem các nội dung đã bị gỡ.
5) **Email** (EmailTrackerPro): xem header (Email → xem original): dòng Received đọc từ trên, SPF/DKIM/DMARC = chống giả mạo.
6) **Google Hacking**: dùng toán tử sites, intitle, inurl, filetype, cache: để lọc info nhạy cảm (kho dữ liệu).
- **Phòng chống**: chính sách giới hạn info công khai / đào tạo NV / ẩn WHOIS / tách DNS / tắt liệt kê web thư mục web / tự thăm dò chính mình (pen test).

(3B) Mục đích: biết máy nào sống / cổng nào mở / chạy service, HTH gì / Có 3 loại: quét công cộng, quét mạng nội bộ, quét máy chủ.
Ping Sweep = ping cả dải IP tìm máy sống.
Nmap (dòng lệnh) / Zenmap (giao diện).

- **Bắt tay TCP**: SYN → SYN/ACK → ACK. Kết thúc: FIN. Hủy ngang: RST. (Khẩn)
- **6 cờ TCP**: SYN (mở) || ACK (xác nhận) || FIN (kết thúc) || RST (hủy) || PSH (đẩy ngang) || URG (khẩn).

- **6 KT quét công** (để cho hình → hỏi tên)

Tên	Gửi Cờ Gì	Đọc Kết quả
TCP Connect	bắt tay đủ 3 bước	SYN/ACK = mở RST = đóng để bị log
SYN (Half-open)	SYN, nhận SYN/ACK rồi RST hủy	"bắt tay nửa chừng" khó log hơn
XMAS	FIN + PSH + URG	im lặng = mở RST = đóng
FIN	chỉ FIN	như XMAS
NULL	0 Cờ nào	như XMAS
UDP	gửi UDP	im lặng = mở ICMP port unreachable = đóng

- **Proxy** = ẩn IP || **Anonymizer/Tor** = xóa toàn bộ định danh || **IP spoofing** = giả IP, phát hiện = TTL lệch.

- **Né IDS**: chia gói độc thành nhiều mảnh nhỏ (fragmentation).
- **P' chống**: firewall + IDS/IPS chặn gói cờ bất thường || đóng cổng thừa || giấu banner || lọc gói chống IP giả || giám sát log.

1) **Phân nhóm Object**: địa chỉ/địa chỉ = Mạng || 1 máy = Hệ thống || Công ty, cty = Tổ chức.
2) **KT quét**: 3 cờ (FIN + PSH + URG) = XMAS || 0 cờ = NULL || 1 cờ FIN = FIN || RST sau SYN/ACK = Half-open || Đủ 3 bước = Connect.

3) **Thư hay chủ động**: Có gửi gói vào máy đích 0? Có = quét (chủ động); 0 = thăm dò (thụ động).

4) **XMAS/FIN/NULL**: im lặng mới là MỞ || RST = Đóng.

5) **ACL, IDS** ∈ nhóm Mạng || bảng định tuyến, SNMP ∈ nhóm Hệ thống.

6) **Proxy chỉ ẩn IP** ≠ **Anonymizer** xóa hết dấu vết.

7) **Trace route** dựa vào ICMP + TTL, 0 gói TCP.

8) **Nhìn** → thụ động; **Gõ cửa** → chủ động.

9) **XMAS** → bắt nhìn cơ nhất || **NULL** = tắt hết đèn.
10) **5 RIR**: Phi - Mỹ - Á - Latin - Âu (AfriNIC; ARIN; APNIC; LACNIC; RIPE).
11) **HINFO** = Host INFORMATION (Thông tin máy chủ) → là CPU + HDD → nguy hiểm nhất.